

PayCarry Türkiye: Zero-CVE Hedefi ve Sürekli PCI DSS Kanıtı İçin Huawei Cloud Güvenlik Mimarisi

1. Yönetici Özeti

PayCarry Türkiye'nin çözmesi gereken temel problem, regüle bir fintech iş yükünü Huawei Cloud TR-Istanbul bölgesine taşıırken mevcut bulut güvenliği borcunu bir sonraki PCI DSS Level 1 yenileme döngüsüne taşımamaktır.

Ana önerim, güvenliği yazılım geliştirme sürecinin en başına alan bir Huawei Cloud DevSecOps mimarisi kurmaktır. Bu modelde güvenlik açıkları canlı ortama çıkmadan önce engellenir, production sunucuları sürekli izlenir ve denetim kanıtları SecMaster, CTS, LTS, Compliance Center ve OBS üzerinden varsayılan olarak üretilir. Amaç "uyumluluk satın almak" değil, güvenli yazılım teslimatını ve denetim kanıtı üretimini PayCarry'nin günlük mühendislik akışının doğal bir parçası hâline getirmektir.

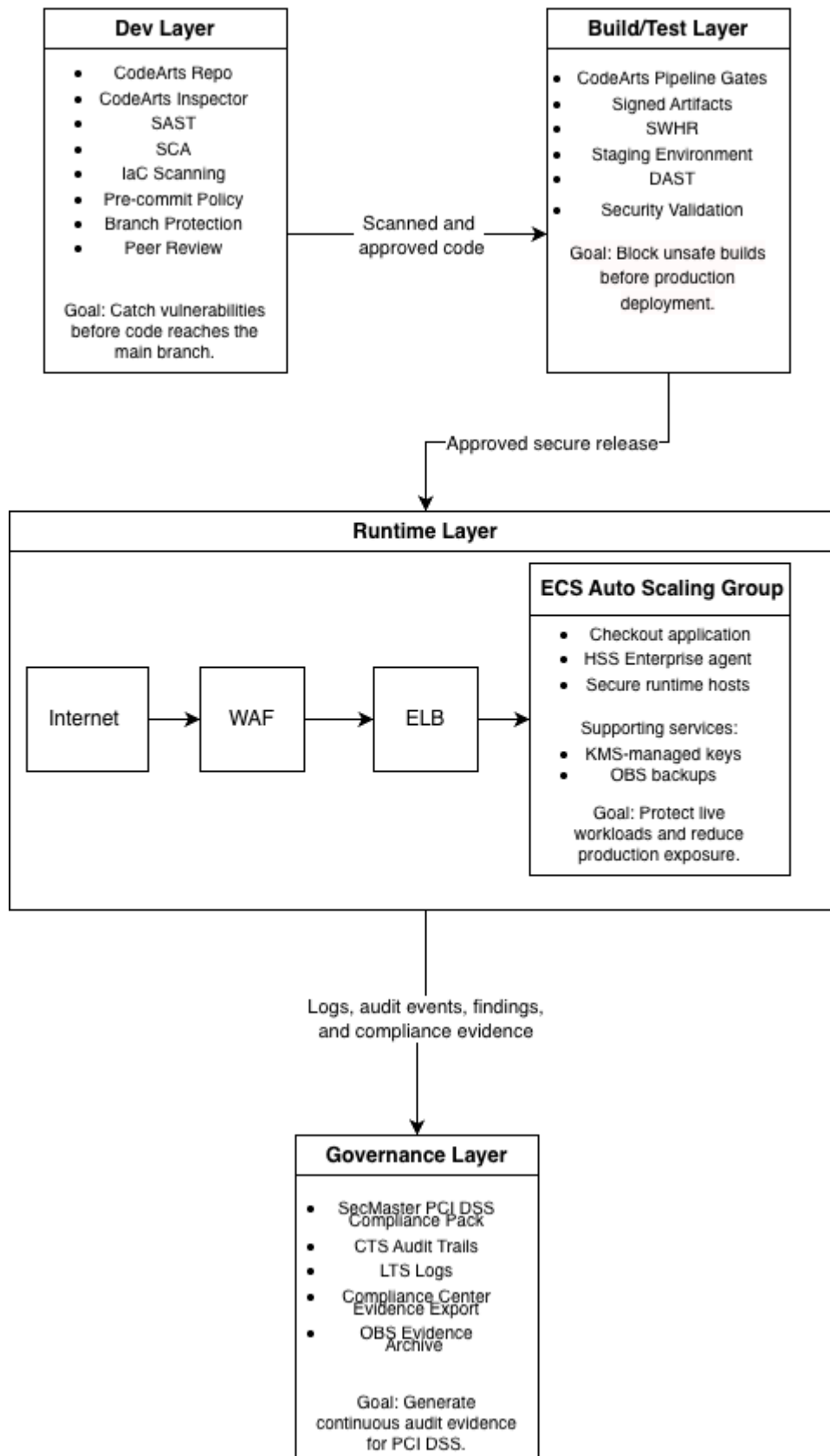
Çalışma başladıktan 90 gün sonra başarılı tablo şudur: PayCarry'nin bir pilot ödeme iş yükü TR-Istanbul'da çalışır, tüm kodlar güvenlik kapılarından geçer, ECS sunucuları HSS Enterprise ile korunur, WAF ve KMS kontrolleri uygulanır, SecMaster baseline kontrolleri aktiftir ve ilk kanıt paketi iç denetim incelemesine hazırdır.

2. Mimari Genel Bakış

Önerilen mimari dört katmandan oluşur: Geliştirme, Derleme/Test, Çalışma Zamanı ve Yönetişim. Bu tasarımda PayCarry'nin önce bir pilot checkout veya merchant transaction servisini taşıması, ardından aynı modeli kart verisi ortamındaki diğer servislere yayması önerilir.

Şekil 1. PayCarry Türkiye için önerilen Huawei Cloud güvenlik mimarisi

Huawei Cloud Security Architecture for PayCarry Türkiye



Geliştirme katmanında CodeArts Repo, uygulama ve altyapı kodu için kontrollü kaynak deposu olur. CodeArts ekosistemi DevSecOps ve CI/CD odaklı yazılım teslim süreçlerini destekler. CodeArts Check ise statik kod kontrolü, kod kalitesi ve siber güvenlik risklerinin erken aşamada tespiti için kullanılabilir. Bu nedenle PayCarry; repository kuralları, protected branch yapısı, pre-commit politikaları ve güvenlik taramalarını kod ana branch'e ulaşmadan önce devreye almalıdır.

Bu katmandaki temel kural basittir: Otomatik güvenlik kontrollerinden ve insan onayından geçmeyen hiçbir kod ana branch'e alınmamalıdır. CodeArts Inspector hedef mimaride güvenlik açığı odaklı inceleme için konumlandırılırken, daha geniş CodeArts araç seti teslimat akışını destekler. PayCarry'nin çalışma modelinde geliştirme katmanı; açıkta kalmış secret'ları, güvensiz bağımlılıkları, riskli kod örüntülerini ve hatalı infrastructure-as-code değişikliklerini deployment artifact'e dönüşmeden önce engellemelidir.

Derleme ve test katmanında CodeArts Pipeline, release sürecinin güvenlik kapısı gibi çalışır. Kritik bir güvenlik açığı, açıkta kalmış secret veya yüksek riskli IaC değişikliği tespit edilirse pipeline başarısız olmalıdır. Onaylanan build'ler imzalı artifact olarak SWHR üzerinde saklanır. Production deployment öncesinde staging ortamında DAST çalıştırılmalıdır. Bu kontroller özellikle login, ödeme, merchant onboarding ve public API endpoint'leri için önemlidir. Bu katman, PayCarry'nin güvenlik politikasını teknik bir mühendislik kuralına dönüştürür: Güvensiz build production'a çıkamaz.

Çalışma zamanı katmanında production ECS sunucuları ELB arkasında çalışır ve dış tarafta WAF ile korunur. WAF; web trafiğini inceleyerek SQL injection, XSS, dosya ekleme, izin geçişi, komut/kod enjeksiyonu, web shell ve üçüncü taraf güvenlik açığı istismarı gibi saldırı türlerine karşı koruma sağlar.

ECS host'larında HSS Enterprise çalışır. HSS Enterprise; host güvenliği, vulnerability management, baseline check, process ve asset görünürlüğü ile runtime protection için kullanılır. Huawei Cloud HSS; asset management, baseline check ve vulnerability management gibi özellikleriyle production ortamındaki güvenlik risklerini görünür hâle getirir. KMS-managed keys, hassas bilgilerin ve şifreleme anahtarlarının güvenli yönetimi için kullanılır. OBS ise backup ve uzun vadeli denetim kanıtı saklama amacıyla konumlandırılır.

Yönetişim katmanında SecMaster, güvenlik operasyonları ve baseline inspection görünümünü sağlar. SecMaster baseline inspection; cloud service konfigürasyonlarını tarayabilir, riskleri kategori bazında raporlayabilir, alert üretebilir ve hardening önerileri sunabilir. CTS, cloud resource operation kayıtlarını güvenlik analizi, uyumluluk denetimi, resource tracking ve hata tespiti için saklar. LTS ise logların merkezi olarak toplanması, sorgulanması, görselleştirilmesi ve saklanması için kullanılır. Compliance Center, sertifikasyon ve evidence export süreçlerini destekler. PayCarry için bu yapı, denetçi taleplerini yılda bir kez yapılan manuel bir telaş olmaktan çıkarıp, tekrarlanabilir aylık bir evidence workflow'a dönüştürür.

3. Production’da “Zero CVEs” Hedefine Nasıl Yaklaşıyoruz?

“Zero CVEs in production” ifadesi mutlak bir garanti olarak değil, hedef işletim modeli olarak görülmelidir. PayCarry bu hedefe, shift-left kontrollerini runtime defense-in-depth yaklaşımıyla birleştirerek yaklaşabilir.

İlk kontrol erken tespittir. Geliştirme aşamasında bulunan bir CVE, production’da bir olay yaşandıktan sonra bulunan aynı CVE’ye göre çok daha ucuz ve daha az yıkıcıdır. Geliştirme aşamasında çözüm çoğu zaman bir bağımlılık güncellemesi, konfigürasyon değişikliği veya küçük bir kod düzeltmesidir. Production’da ise aynı açık; incident response, emergency change approval, müşteri iletişimi, regülatör bildirimi, forensic investigation ve downtime planlaması gerektirebilir. Bu nedenle Session 2’de anlatılan maliyet eğrisi önemlidir: Bir hata ne kadar geç bulunursa maliyeti ve operasyonel etkisi o kadar artar. PayCarry için her kritik CVE, release öncesinde pipeline’ı durdurmalıdır.

İkinci kontrol bağımlılık disiplindir. SCA; uygulama kütüphaneleri, container image’ları ve açık kaynak bağımlılıkları için zorunlu olmalıdır. IaC taraması ise public security group, zayıf OBS bucket policy veya eksik encryption gibi riskli bulut değişikliklerini uygulanmadan önce yakalamalıdır. Migration döneminde bu kontroller daha da önemlidir çünkü altyapı hızlı değişir ve yapılan hatalar farklı ortamlara kolayca kopyalanabilir.

Üçüncü kontrol runtime güvenlik ağıdır. HSS Enterprise, ECS iş yükleri için vulnerability management sağlar ve işletim sistemi ile yazılım güvenlik açıklarının tespit edilmesine yardımcı olur. Huawei Cloud HSS, çok sayıda güvenlik açığını tarayabildiğini ve bazı açıklar için one-click fix sağlayabildiğini belirtir. Ancak PayCarry production sunucularını kör şekilde patch’lememelidir.

Güvenli akış şu olmalıdır: Açığı sınıflandır, iş etkisini değerlendir, ECS snapshot al veya rollback imkânını doğrula, düzeltmeyi önce staging ortamında uygula, ardından kontrollü bakım penceresinde production’a taşı. “Snapshot-before-fix” yaklaşımı, bir patch ödeme bağımlılığını bozarsa ekibe geri dönüş yolu sağlar.

Dürüst uyarı şudur: Hiçbir bulut mimarisi kalıcı “zero CVE” garantisi veremez. Log4Shell benzeri emergency vulnerability olayları aniden ortaya çıkabilir ve scanner’lar, vendor’lar ve iç ekipler henüz tam uyum sağlamadan önce exploitation başlayabilir. Bu nedenle PayCarry’nin yine de acil müdahale süreci olmalıdır: hızlı exposure assessment, geçici WAF kuralları, etkilenen asset inventory, compensating controls, emergency patching ve executive notification.

Bu yüzden başarı metriği “asla CVE görmeyeceğiz” olmamalıdır. Daha gerçekçi başarı metriği şudur: Kritik CVE’ler normal release süreciyle production’a ulaşmaz, runtime CVE’ler hızlı tespit edilir, emergency vulnerability’ler saatler içinde triage edilir ve remediation kanıtı otomatik olarak toplanır.

4. Sürekli PCI DSS Kanıtı Nasıl Üretiriz?

PCI DSS kanıtları yılda bir kez toplanmamalıdır. PayCarry için bu kanıtlar platform tarafından sürekli üretilmelidir. PCI DSS; ödeme kartı verilerinin saklandığı, işlendiği veya iletildiği ortamları korumak için teknik ve operasyonel gereklilikler tanımlar.

İlk adım, SecMaster'da PCI DSS compliance pack'e abone olmak ve TR-Istanbul ortamı için baseline inspection'ı etkinleştirmektir. SecMaster baseline inspection; cloud konfigürasyonlarını tarayabilir, riskleri kategori bazında raporlayabilir, alert üretebilir ve hardening önerileri sunabilir. Bu, PayCarry'ye sadece denetim öncesi güncellenen bir spreadsheet yerine yaşayan bir compliance dashboard sağlar.

Bazı kontroller otomatikleştirilebilir. Örneğin logging'in açık olup olmadığı, riskli network konfigürasyonlarının bulunup bulunmadığı veya güvenlik servislerinin aktifliği otomatik kontrol edilebilir. Ancak bazı maddeler manuel kalır. Politika onayı, çalışan eğitimi, incident response tatbikatları ve prosedürlerin gerçekten uygulanıp uygulanmadığı gibi konular hâlâ insan beyanı ve süreç kanıtı gerektirir.

Somut örnek olarak PCI DSS Requirement 1 seçilebilir. Bu madde network security controls üzerine odaklanır. Önerilen mimaride WAF public web uygulamalarını korur, ELB inbound service exposure'ı yönetir, VPC security group'ları network path'leri sınırlar ve perimeter access rule'lar istenmeyen trafiği azaltır. CTS, network resource'lar üzerindeki administrative change kayıtlarını tutar. LTS, access ve security log'larını saklar. SecMaster baseline check'leri riskli network konfigürasyonlarını bulup remediation için finding üretir. Böylece PCI beklentisi, Huawei Cloud kontrolü ve denetim kanıtı arasında doğrudan bir zincir oluşur.

İkinci kanıt akışı kimlik ve operasyon kanıtıdır. CTS, cloud resource operation kayıtlarını tutar ve security analysis, compliance auditing, resource tracking ve fault locating süreçlerini destekler. PCI auditor açısından bu önemlidir çünkü PayCarry kimin, neyi, ne zaman, nereden değiştirdiğini ve değişikliğin yetkili olup olmadığını gösterebilmelidir. CTS trace'leri uzun vadeli kanıt için export edilmeli veya saklanmalıdır.

LTS ise application log, WAF log, ELB log ve security log'larını toplamalıdır. Böylece ekip olayları arayabilir, rapor üretebilir ve geçmişini yeniden inşa etmek zorunda kalmaz. LTS'nin merkezi log toplama, sorgulama, görselleştirme ve OBS'de uzun süreli saklama yetenekleri bu model için önemlidir.

Compliance Center burada kanıt paketleme katmanı olur. Denetim öncesi mühendislerden screenshot, policy, log ve certificate toplamalarını istemek yerine PayCarry aylık evidence export rutini oluşturabilir. Compliance Center materyalleri, SecMaster finding'leri, CTS trace'leri, LTS raporları, HSS vulnerability raporları ve change approval kayıtları; sıkı IAM erişimi ve KMS encryption ile korunan bir OBS evidence bucket içinde saklanabilir.

Dürüst uyarı: PCI DSS yalnızca cloud configuration standardı değildir. Hiçbir cloud provider; PayCarry'nin çalışanlarını eğittiğini, politikaları onayladığını, risk assessment yaptığını, vendor süreçlerini yönettiğini veya incident response prosedürlerini gerçekten uyguladığını otomatik olarak kanıtlayamaz. Huawei Cloud teknik kanıtları sürekli hâlâ getirebilir; ancak

governance, accountability ve business process evidence PayCarry'nin sorumluluğunda kalır.

5. Risk Kaydı

Risk	Olasılık	Etki	Azaltma Yöntemi
Türkiye'de Huawei Cloud deneyimli mühendis sayısının AWS veya Azure'a göre daha az olması	Orta	Orta	Platform ekibini erken eğitmek, iç runbook hazırlamak ve migration sırasında Huawei Cloud support kullanmak.
TR-Istanbul bölgesinde bazı servis özelliklerinin global bölgelerle aynı anda gelmemesi	Orta	Yüksek	Final migration öncesi gerekli SecMaster, HSS, CodeArts, WAF, KMS ve Compliance Center özelliklerini tek tek doğrulamak.
PCI renewal takvimi ile migration takviminin çakışması	Orta	Yüksek	Pilot workload ile başlamak, mevcut audit evidence'ı korumak ve full cardholder data environment geçişini çok geçe bırakmamak.
Partner veya procurement tarafında cloud provider riski endişesi	Düşük/Orta	Orta	Huawei Cloud Trust Center, Compliance Center, shared responsibility dokümanları ve mimari kanıtlarla due diligence paketi hazırlamak.
Huawei-specific DevSecOps araçlarına lock-in oluşması	Orta	Orta	Policy-as-code kullanmak, scan sonuçlarını export etmek, standart artifact formatları kullanmak ve repository/pipeline exit planı oluşturmak.

En büyük risk zamanlamadır. PayCarry'nin PCI DSS Level 1 renewal için 18 ayı vardır; bu rahat gibi görünür. Ancak cloud migration, application refactoring, evidence generation ve audit remediation bu sürenin önemli kısmını tüketebilir. Bu nedenle migration tek seferlik büyük geçiş değil, aşamalı ilerleyen kontrollü bir program olmalıdır.

6. İlk 90 Gün Planı

İlk 90 günün amacı tüm sistemi taşımak değil, modeli temsili bir iş yüküyle kanıtlamaktır.

Hafta 1–2: Foundation

- Huawei Cloud account, project ve IAM group'ları oluřtur.
- MFA ve least privilege uygula.
- VPC, subnet, security group, KMS, OBS, CTS ve LTS landing zone kur.
- Evidence bucket yapısını ve retention kurallarını belirle.

Hafta 3–6: Pilot Runtime

- Bir pilot workload'u TR-Istanbul'a taşı.
- ECS'leri ELB ve WAF arkasına yerleřtir.
- Tüm pilot ECS host'larında HSS Enterprise etkinleřtir.
- SecMaster baseline inspection'ı aç.
- Application, WAF, ELB ve host log'larını LTS'ye gönder.

Hafta 7–10: DevSecOps Pipeline

- Pilot repository'yi CodeArts Repo'ya taşı.
- CodeArts Inspector ve CodeArts Check gate'leriyle SAST, SCA ve IaC odaklı kontroller ekle.
- Critical CVE içeren build'lerin production'a çıkmasını engelle.
- Signed artifact'ları SWHR içinde sakla.
- Production release öncesi staging'de DAST çalıştır.

Hafta 11–13: Compliance Evidence

- PCI DSS compliance pack'e abone ol.
- İlk baseline scan'i çalıştır.
- High-risk gap'leri kapat.
- CTS, LTS, HSS, SecMaster ve Compliance Center evidence export'larını al.
- CTO, security lead ve compliance owner ile mock audit yap.

90 günün sonunda PayCarry final PCI readiness iddia etmemelidir. Daha güvenilir iddia řudur: Migration control pattern çalışıyor, evidence sürekli üretiliyor ve kalan gap'ler görünür, atanmış ve takvimlendirilmiş durumda.

Kaynaklar

1. Huawei Cloud CodeArts Product Page — <https://www.huaweicloud.com/intl/en-us/product/devcloud.html>
2. Huawei Cloud CodeArts Check Documentation — <https://support.huawei.com/enterprise/en/doc/EDOC1100372275/828e00d3/what-is-codearts-check>
3. Huawei Cloud CodeArts Inspector Documentation — <https://support.huawei.cn/enterprise/en/doc/EDOC1100521524/6b02a07b/what-is-codearts-inspector>

4. Huawei Cloud Host Security Service Product Page —
<https://www.huaweicloud.com/intl/en-us/product/hss.html>
5. Huawei Cloud SecMaster Baseline Inspection Documentation —
https://support.huaweicloud.com/intl/en-us/usermanual-secmaster/secmaster_02_0028.html
6. Huawei Cloud Cloud Trace Service Product Page —
<https://www.huaweicloud.com/intl/en-us/product/cts.html>
7. Huawei Cloud Log Tank Service Product Page —
<https://www.huaweicloud.com/intl/en-us/product/lts.html>
8. Huawei Cloud Web Application Firewall Product Page —
<https://www.huaweicloud.com/intl/en-us/product/waf.html>
9. Huawei Cloud Data Encryption Workshop Product Page —
<https://www.huaweicloud.com/intl/en-us/product/dew.html>
10. Huawei Cloud PCI DSS Compliance Center —
<https://www.huaweicloud.com/intl/en-us/securecenter/compliance/compliance-center/pci-dss.html>
11. PCI Security Standards Council PCI DSS Standards Page —
<https://www.pcisecuritystandards.org/standards/>